



Vulnerability Assessment and Penetration Testing Report

Damn Vulnerable Web Application (DVWA) Security Assessment

Submitted by

PALLAPU MAHESH

1EP22EC074

Submitted to

External Guide,

Mr. Jacob Dennis P,

Campuspe, Bangalore.



Client	Metasploitable 2 Test Environment
Application	DVWA (Damn Vulnerable Web Application)
Report Date:	MAY 9-2026
Prepared By	PALLAPU MAHESH
Submitted to	Campuspe support team
Role	Security Reviewer
URL:	http://192.168.143.129/dvwam/

CONTENT

1. Executive Summary	4
2. Objectives	4-6
3. Scope of Assessment	6-8
4. Testing Methodology	8-9
5. Tools	9
6. Vulnerability Details	
6.1. Remote Code Execution – CVE-2012-1823 (High Risk)	9-11
6.2. Source Code Disclosure – CVE-2012-1823 (High Risk)	11-12
6.3. Absence of Anti-CSRF Tokens (Medium Risk)	12-13
6.4. SQL Injection (Critical)	13-14
6.5. Command Injection / OS Command Execution (Critical)	14-15
6.6. Unrestricted File Upload (Critical)	15-16
6.7. Reflected Cross-Site Scripting (XSS) (High)	16-17
7. Conclusion	18

1. Executive Summary

A Vulnerability Assessment and Penetration Testing (VAPT) assessment was conducted against the Damn Vulnerable Web Application (DVWA) hosted on the Metasploitable 2 Lab virtual machine.

The objective of the assessment was to identify security weaknesses, validate exploitable vulnerabilities, and analyze the overall security posture of the target application.

The assessment identified multiple vulnerabilities including:

- SQL Injection
- Cross-Site Scripting (XSS)
- Command Injection
- Missing Security Headers
- Weak Cookie Security Configuration
- Absence of CSRF Protection
- Information Disclosure
- Remote Code Execution Exposure

The testing demonstrated that insecure input handling and outdated server configurations can expose applications to severe security risks.

2. Objectives

The objectives of this assessment were:

- Perform reconnaissance and service enumeration
- Identify web application vulnerabilities
- Validate vulnerabilities through controlled testing
- Analyze risk and impact
- Recommend mitigation strategies
- Demonstrate practical cybersecurity assessment methodology

Overall Risk Level: HIGH

The assessment **identified 13** security findings across multiple severity levels.

Of significant concern are **2 High** severity vulnerabilities that pose substantial risk to the target application and underlying infrastructure.

These vulnerabilities could allow attackers to:

- Execute arbitrary commands on the web server
- Access sensitive application data
- Exploit weak session and cookie security
- Perform Cross-Site Request Forgery (CSRF) attacks
- Gather server information for further exploitation
- Bypass browser-side security protections

Severity	Count	Percentage	CVSS Range	Priority
Critical	0	0%	9.0-10.0	P0 - Immediate
High	2	15%	7.0-8.9	P1 - Urgent
Intermediate	3	43%	4.0 – 6.9	P2 - Importan
low	6	26%	0.1 – 3.9	P3 - Standard
Informational	2	16%	-	Monitoring
Total	13	100%	-	-

Critical Observations**High Severity Findings**

- Remote Code Execution (CVE-2012-1823)
- Source Code Disclosure

Medium Severity Findings

- Absence of Anti-CSRF Tokens
- Missing Content Security Policy (CSP)
- Missing Anti-Clickjacking Protection

Low Severity Findings

- Cookie Without Http Only Flag
- Cookie Without Same Site Attribute
- Server Version Information Disclosure
- X-Content-Type-Options Header Missing

- Information Leakage via HTTP Headers

Recommendations

Immediate (0–24 Hours)

- Patch vulnerable PHP CGI components affected by CVE-2012-1823
- Disable unnecessary server information disclosure
- Restrict execution of untrusted input

Short-Term (1–7 Days)

- Implement CSRF protections across forms
- Configure Content Security Policy (CSP)
- Enable X-Frame-Options and X-Content-Type-Options headers

Long-Term

- Perform regular VAPT assessments
- Harden server configuration following OWASP standards
- Implement secure cookie attributes and session management controls

3. Scope of Assessment

Target Environment

Item	Details
Target Application	DVWA (Damn Vulnerable Web Application)
Target Platform	Metasploitable 2
Target IP Address	192.168.142.129
Testing Environment	Isolated Virtual Lab
Operating System	Ubuntu Linux
Web Server	Apache 2.2.8
Backend Language	PHP 5.2.4
Database	MySQL

In Scope

- Web application testing
- HTTP header analysis
- Vulnerability scanning
- Authentication analysis
- Input validation testing
- Manual and automated assessment

Out of Scope

- Denial of Service (DoS)
- Social Engineering
- Physical Security
- Real-world external targets
- Persistence or destructive exploitation

4. Testing Methodology

The assessment followed a structured VAPT methodology.

Phase 1 – Reconnaissance

Performed target discovery and service enumeration.

Activities:

- Port scanning
- Service detection
- Technology identification
- Web enumeration

```

kali@kali: ~/project
└─$ sudo nmap -v -o - 192.168.142.129 -n Reason:txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-09 10:11 -0400
Map engine version for 192.168.142.129:
Host is up (0.001% latency).
Not shown: 65536 closed tcp ports (reset)
Nmap scan information:
Host: 192.168.142.129
OS: Linux 2.6.32
Device type: general purpose
Running: Linux 2.6.32
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.32
Network Distance: 1 hop
Service Info: Hosts: metasploit.localdomain, irc.Metasploitable.LAN; OSes: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

21/tcp open ftp vsftpd 2.3.4
22/tcp open ssh OpenSSH 4.7p1 Debian Shumailo (protocol 2.0)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
80/tcp open http Apache/2.2.8 ((Ubuntu) DAV/)
111/tcp open rpcbind 2 (RPC #100000)
139/tcp open smb Samba smbd 3.0.x - 4.x (workgroup: WORKGROUP)
143/tcp open netbios-ssn Samba smbd 3.0.x - 4.x (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.x - 4.x (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rshexec
513/tcp open login netkit-rsh rlogind
514/tcp open shell Netkit rshd
515/tcp open java.rmi GNU Classpath gmrregistry
1524/tcp open bindshell Metasploitable root shell
3043/tcp open rls 2-x (RPC #100003)
7121/tcp open ftp ProFTPD 1.3.1
1306/tcp open mysql MySQL 5.0.51a 3ubuntu5
1322/tcp open distccd distccd v1 ((GNU) 4.2.4 ((Ubuntu) 4.2.4-1ubuntu4))
1632/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
1638/tcp open vnc VNC (protocol 3.3)
5000/tcp open x11 (access denied)
5662/tcp open irc UnrealIRCd
5687/tcp open irc UnrealIRCd
8080/tcp open ajp13 Apache Jserv (Protocol v1.3)
8180/tcp open http Apache/2.2.8 (Ubuntu) DAV engine 1.1
8787/tcp open drb Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
18627/tcp open nlockmgr 1-x (RPC #100021)
18773/tcp open status 1 (RPC #100024)
44570/tcp open java.rmi GNU Classpath gmrregistry
4745/tcp open mountd 1-x (RPC #100035)
MAC Address: 00:0C:12:9:1F:FB:IDA (VMware)
Device type: general purpose
Running: Linux 2.6.32
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.32
Network Distance: 1 hop
Service Info: Hosts: metasploit.localdomain, irc.Metasploitable.LAN; OSes: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.

```

Phase 2 – Vulnerability Assessment

Performed automated and manual security testing.

Activities:

- Nikto scanning
- OWASP ZAP scanning
- Header analysis
- Input validation testing

```
kali@kali:~/project
$ nikto -u http://192.168.142.129/dvwa/
Nikto v2.1.6.0

+ Target IP: 192.168.142.129
+ Target Hostname: 192.168.142.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2020-05-09 10:23:03 (GMT+4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /dvwa/: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.18
+ [951] /dvwa/: Cookie HttpOnly created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [704006] /dvwa/index/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999986] /dvwa/robots.txt: Server may leak inodes via flags, header found with file /dvwa/robots.txt, inode: 93164, size: 26, mtime: Tue Mar 16 01:56:22 '20
ID: See: https://cwe.mitre.org/data/entries/entry.cgi?name=CWE-7803-1418
+ [400030] Apache/2.2.8 appears to be outdated (current is at least 2.4.6).
+ [400022] PHP/5.2.4-2ubuntu5.18 appears to be outdated (current is at least 8.0.1).
+ [013587] /dvwa/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /dvwa/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /dvwa/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /dvwa/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /dvwa/: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [999186] /dvwa/index: (no-common header(s)) line found, with contents: 111.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=46986bdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [000424] //: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750500] /dvwa/config/: Directory indexing found.
+ [400996] /dvwa/config/: Configuration information may be available remotely.
+ [001384] /dvwa/h.php?PHPSESSID=3C92-1d3-A3A9-4C708AC18000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /dvwa/h.php?PHPSESSID=3C92-1d3-A3A9-4C708AC18000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /dvwa/h.php?PHPSESSID=3C92-1d3-A3A9-4C708AC18000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /dvwa/h.php?PHPSESSID=3C92-1d3-A3A9-4C708AC18000: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writups/do-you-dare-to-show-your-php-easter-egg/
+ [001388] /dvwa/login/: This might be interesting.
+ [001389] /dvwa/login.php: Admin login page/section found.
+ [001390] /dvwa/login.php: Admin login page/section found.
+ [001391] /dvwa/login.php: Admin login page/section found.
+ [001392] /dvwa/: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ [001393] /dvwa/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.wisec.it/sectou.php?id=46986bdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ 8275 requests: 16 errors and 76 items reported on the remote host
+ End Time: 2020-05-09 10:28:00 (GMT+4) (337 seconds)

+ 1 host(s) tested
kali@kali:~/project
$
```

Phase 3 – Vulnerability Validation

Validated vulnerabilities manually inside the isolated lab.

Activities:

- SQL Injection testing
- XSS testing
- Command Injection testing
- Authentication analysis

5. Tools Used

Tool	Purpose
Kali Linux	Penetration testing platform
Nmap	Network reconnaissance and enumeration
Nikto	Web server vulnerability scanning
OWASP ZAP	Automated web application security scanning
Burp Suite	Web application request analysis
Firefox Browser	Web testing and validation

6. Vulnerability Details

6.1. Remote Code Execution – CVE-2012-1823 (High Risk)

Vulnerability

Remote Code Execution (RCE) allows an attacker to execute arbitrary system commands on the target server.

Affected Target

<http://192.168.142.129/dvwa/>

CVE

CVE-2012-1823

Risk Level

- Risk: High
- Confidence: Medium

Description

This vulnerability affects older PHP CGI configurations.

An attacker can manipulate query strings and inject PHP directives into the request, resulting in arbitrary command execution.

The scan indicates the server accepted malicious PHP parameters through the URL.

Evidence Found

➤ w3gw669dqdfix39mhsc1

Attack Payload Observed

```
<?php exec('echo w3gw669dqdfix39mhsc1',$colm);echo join('',$colm);die();?>
```

Why It Is Dangerous

An attacker may:

- Execute OS commands
- Upload web shells
- Gain server access
- Read sensitive files
- Pivot deeper into the network
- Fully compromise the web application

Technical Cause

The server is running:

- Apache/2.2.8
- PHP/5.2.4

Older PHP CGI versions improperly process malformed query strings.

Remediation

- Upgrade PHP to a secure version
- Disable vulnerable CGI mode
- Use PHP-FPM instead of CGI
- Apply latest Apache security patches
- Configure ModSecurity WAF rules
- Restrict dangerous PHP functions:

`exec()`

`system()`

`shell_exec()`

- Validate and sanitize all inputs

6.2 Source Code Disclosure – CVE-2012-1823 (High Risk)

Vulnerability

Source Code Disclosure occurs when server-side application code becomes accessible to attackers.

Risk Level

- Risk: High
- Confidence: Medium

Description

Due to improper PHP CGI handling, the server may expose raw PHP source code instead of executing it.

Attackers can retrieve:

- Application logic
- Credentials
- Database connection strings
- API keys
- Hidden endpoints

Potential Sensitive Information

- MySQL usernames/passwords
- Admin credentials
- Session handling logic
- Hidden parameters
- File paths

CWE

CWE-200

Remediation

- Upgrade vulnerable PHP version
- Disable PHP CGI if unused
- Restrict direct access to sensitive files
- Remove backup/source files:
 - .bak
 - .old
 - .zip

- Configure proper Apache handlers
- Use least privilege permissions

6.3 Absence of Anti-CSRF Tokens (Medium Risk)

Vulnerability

Cross-Site Request Forgery (CSRF) allows attackers to force authenticated users to perform unwanted actions.

Risk Level

- Medium

Description

The application does not include CSRF protection tokens in sensitive requests.

Attack Scenario

An attacker tricks a logged-in victim into visiting a malicious page that silently sends requests to the vulnerable application.

Impact

- Password changes
- Unauthorized transactions
- Account manipulation
- Privilege changes

CWE

CWE-352

Remediation

- Add CSRF tokens to forms
- Validate tokens server-side
- Use Same Site cookie attribute
- Require re-authentication for critical actions
- Implement Origin/ Referer validation

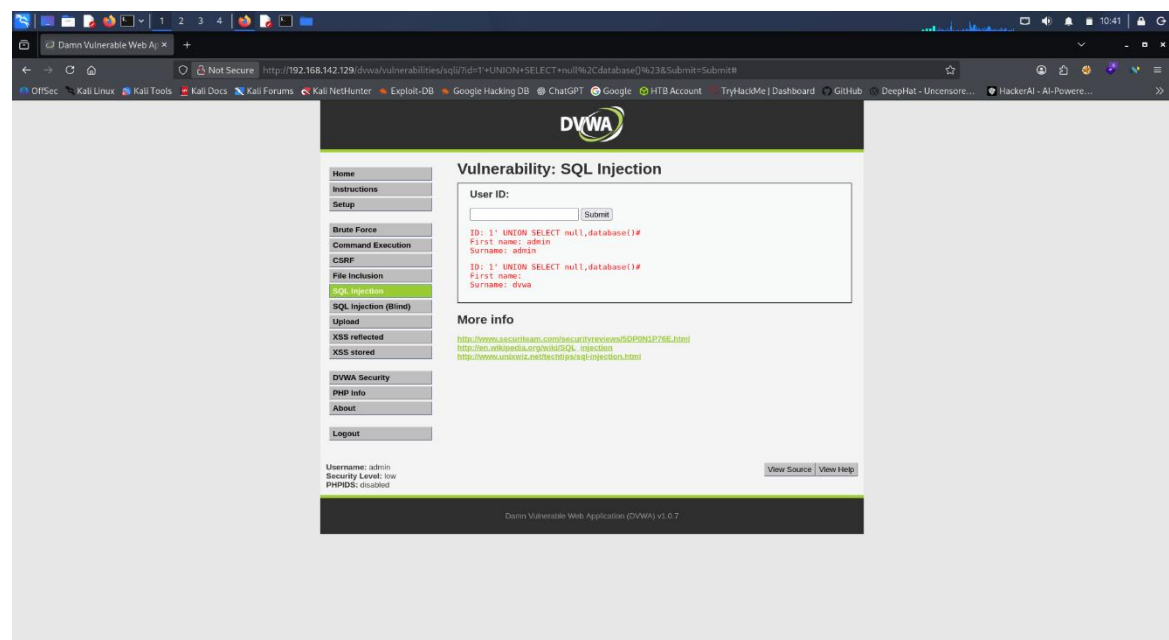
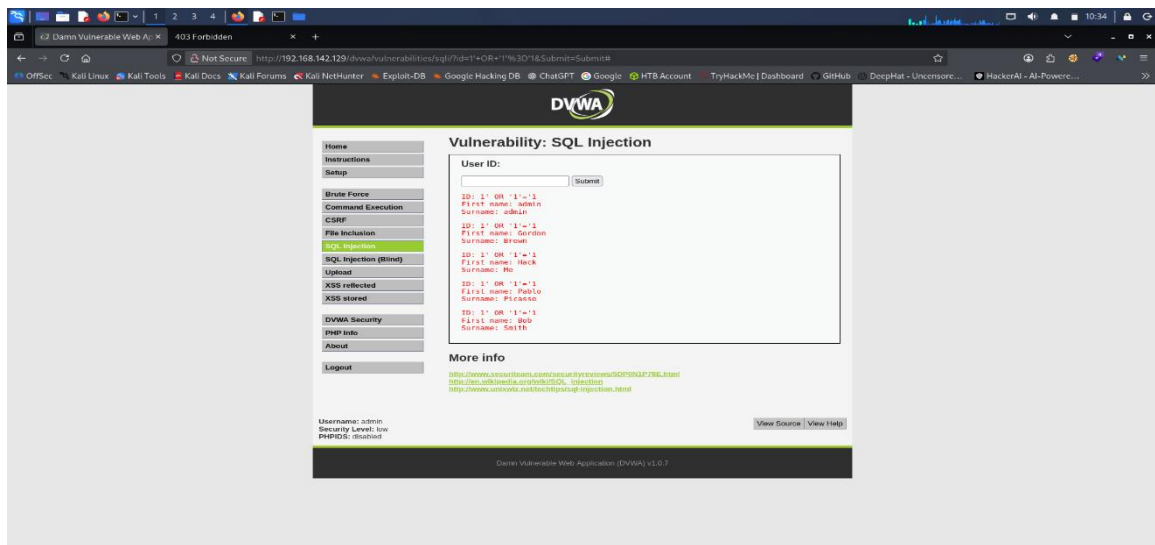
6.4 SQL Injection (Critical)

Vulnerability

- SQL Injection

Risk Level

- Critical
- Evidence from Screenshot



Payload used:

➤ 1' OR '1'='1

Result:

Multiple database records displayed

Authentication/query bypass successful

Another payload:

➤ 1' UNION SELECT null,database()#

Description

The application directly concatenates user input into SQL queries without proper sanitization.

Impact

An attacker can:

- Bypass authentication
- Dump database contents
- Extract usernames/passwords
- Modify or delete records
- Gain administrative access

CWE

- CWE-89

OWASP Category

- A03:2021 – Injection

Remediation

- Use prepared statements
- Implement parameterized queries
- Validate user input
- Apply least privilege DB accounts
- Use ORM frameworks securely

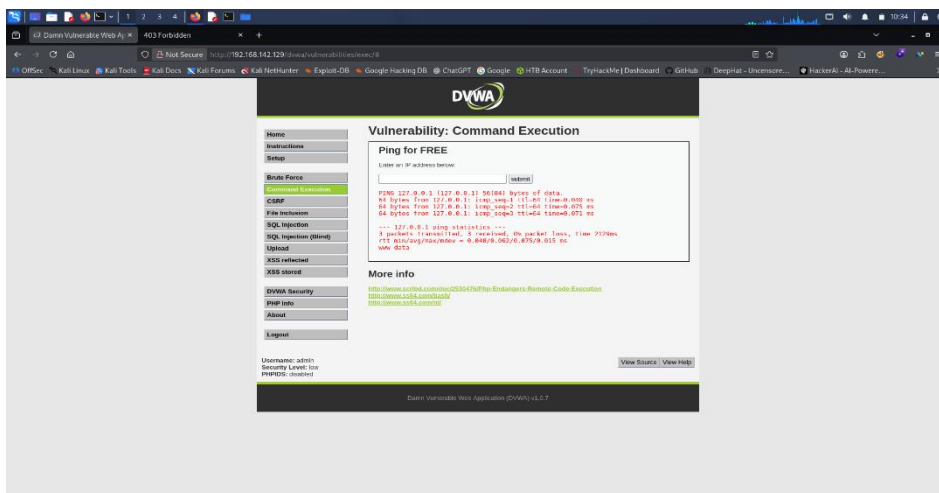
6.5 Command Injection / OS Command Execution (Critical)

Vulnerability

OS Command Injection

Risk Level

- Critical
- Evidence



Payload observed:

- 127.0.0.1 && whoami

Output:

- www-data

Description

The application executes user-controlled input in system shell commands.

Impact

An attacker can:

- Execute arbitrary commands
- Read/write server files
- Install malware
- Obtain reverse shells
- Fully compromise the server

CWE

- CWE-78

Remediation

- Avoid shell execution functions
- Use allowlists for input
- Escape shell arguments
- Run services with minimal privileges
- Disable dangerous PHP functions

6.6 Unrestricted File Upload (Critical)

Vulnerability

Unrestricted File Upload

Risk Level

- Critical
- Evidence

Uploaded file:

➤ code.desktop

Upload success message:

➤ successfully uploaded

Description

The application accepts uploaded files without proper validation of

- File type
- MIME type
- Extension
- Content

Impact

An attacker may:

- Upload web shells
- Execute malicious scripts
- Store malware

VAPT Report

- Achieve remote code execution

CWE

- CWE-434

Remediation

- Allow only safe extensions
- Validate MIME types
- Rename uploaded files
- Store uploads outside web root
- Scan files for malware
- Disable script execution in upload directories

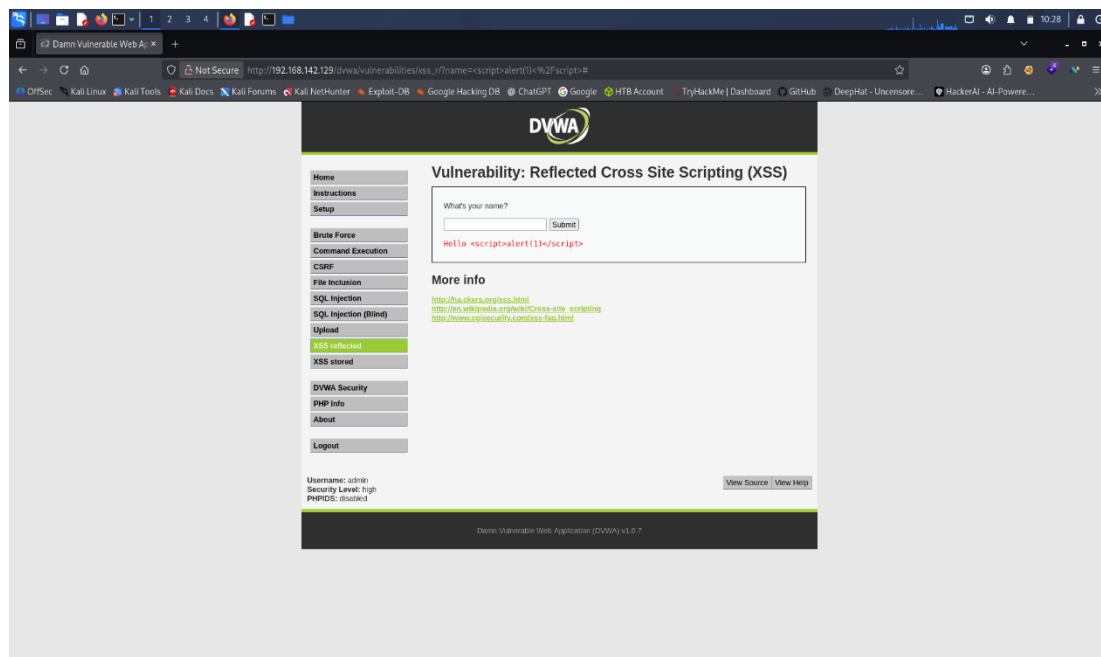
6.7 Reflected Cross-Site Scripting (XSS) (High)

Vulnerability

Cross-Site Scripting

Risk Level

- High
- Evidence



Payload:

- `<script>alert(1)</script>`

Application response:

- Hello `<script>alert(1)</script>`

Description

User input is reflected into the page without proper encoding or sanitization.

Impact

An attacker can:

- Steal session cookies
- Hijack accounts
- Redirect users
- Inject malicious JavaScript
- Perform phishing attacks

CWE

- CWE-79

Remediation

- Encode output properly
- Sanitize user input
- Implement CSP headers
- Use secure frameworks
- Validate allowed characters

Conclusion

The VAPT assessment conducted against DVWA in the isolated Metasploitable 2 environment identified multiple critical and high-risk vulnerabilities, including SQL Injection, Command Injection, Unrestricted File Upload, and Cross-Site Scripting.

The findings demonstrate that insecure coding practices, outdated server configurations, and insufficient input validation can significantly compromise application security.

Immediate remediation is strongly recommended to reduce the attack surface and improve the overall security posture of the environment.

This assessment successfully demonstrated practical vulnerability identification, exploitation, risk analysis, and mitigation techniques within a controlled laboratory environment.